



File No.: EXP202400058

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On January 23, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against CAJA RURAL DE SALAMANCA, S.C.C. (hereinafter referred to as the claimed party). After notifying the agreement to initiate and analyzing the allegations presented, on December 3, 2024, the proposal for resolution was issued, which is transcribed below:

<<

File No.: EXP202400058

PROPOSAL FOR RESOLUTION OF SANCTIONING PROCEDURE

From the procedure initiated by the Spanish Agency for Data Protection and based on the following:

BACKGROUND

FIRST: On December 13, 2022, a security breach of personal data of the entity belonging to the CAJA RURAL GROUP: CAJA RURAL DE SALAMANCA, S.C.C. with NIF F37015856 (hereinafter, CAJASALAMANCA or the entity) was notified as responsible for the processing.

It should be noted that, as a result of notifications to the Division of Technological Innovation of this Agency regarding the breach of personal data in various Entities of the aforementioned Group, including the claimed party, related to a cyber-incident, the General Subdirectorate of Data Inspection was ordered to carry out the appropriate preliminary investigations in order to determine a possible violation of data protection regulations.

1. Initially, the notifications of the breach were made by the data processor RURAL SERVICIOS INFORMÁTICOS S.L. (hereinafter RSI), concerning 19 entities of the Group:

2. The initial notification and additional notification dates are: December 12, 2022, and January 10, 2023.

3. However, on December 13, 2022, December 14, 2022, and December 15, 2022, notifications of the breach were made by another 7 entities of the group, including the entity, in its capacity as data controllers, despite the fact that the data processor is the same.

The breach notification forms are accompanied by the Security Incident Report prepared in all cases by RSI, the data processor.

- Date of breach detection: December 9, 2022

- Date of breach occurrence: November 10, 2022

- Summary of the notification:

(...)

- Type of affected data:

(...)

- Approximate number of individuals whose personal data is collected, stored, or otherwise processed exclusively related to the processing in which the breach occurred, No. of individuals (...).

- Approximate number of individuals whose data has been affected by the breach, No. affected (...).

- No. communicated (...).

SECOND: As a consequence of the notifications to the Division of Technological Innovation of this Agency regarding the breach of personal data in various Entities of the CAJA RURAL GROUP related to a cyber-incident, the General Subdirectorate of Data Inspection is ordered to carry out the appropriate preliminary investigations in order to determine a possible violation of data protection regulations.

During the present proceedings, the following entities have been investigated:

- (...)

In order to investigate the occurrence of the described facts, on March 29, 2023, a request for information was made to RSI. The response to the request was received on April 14, 2022.

On May 12, 2023, and September 27, 2023, RSI was requested to expand the information provided, and on May 26, 2023, and October 11, 2023, responses were received at the electronic headquarters of the AEPD.

In order to introduce the applications involved in the breach that will be referenced throughout this report, the description provided in the documentation submitted by RSI in the context of the investigation proceedings is reproduced below:

(...)

Furthermore, RSI, in its document received at the AEPD on April 14, 2023, states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/58

Currently, the only available Electronic Banking application is the NBE, except for some accesses to Ruralvía Clásica that are maintained to ensure the continuity of operations in certain cases, and we are currently in the process of gradually phasing it out, which will be completed throughout the month of May.

Since not 100% of the operations that existed in Ruralvía Clásica are available in the NBE, only for these specific operations, access to Ruralvía Clásica is granted through reinforced SSO according to a user profiling and not to the entire website. This access to Ruralvía Clásica does not imply that the user navigates to this application in the same or different tab of the browser, but rather that the user only accesses the desired operation within a frame (iframe) in the NBE application, which is never left. In other words, the application embeds the HTML of Ruralvía Clásica corresponding to the desired operation within the HTML of the NBE application. We will refer to this mechanism hereinafter as access via iframe controlled by reinforced SSO.

Therefore, there is no free navigation through Ruralvía Clásica, and additionally, when accessing any operation of Ruralvía Clásica, it is not possible to return to the NBE, to ensure greater security.

Regarding the functionalities of the web and mobile applications, as is the case with the generality of digital banking of any financial entity, it can be stated that, in general, most operations possible for the vast majority of bankable products marketed by the CCRR can be performed.

[...]

These operations are automatically associated with the client when they are registered, based on the products they have contracted.

The existing migration plan stipulates that by September 2023, the mechanism previously explained, by which some operations available in NBE are provided through access, within an iframe of NBE, controlled by reinforced SSO, to the Ruralvía Clásica operations, will disappear, with the exceptions that will be mentioned. At that time, all operations will be developed in the new NBE application, which will mean the effective discontinuation of Ruralvía Clásica.

The exceptions referred to in the previous paragraph are a set of operations related to Savings-Investment and Foreign products. The digitization of these products has its own agenda, which requires a total rethinking of how they are provided digitally, so the operations related to this agenda that are currently provided through access to the Ruralvía Clásica operations via an iframe in NBE controlled by reinforced SSO will continue to be provided through this mechanism beyond the month of September, for the time until their development in execution of the roadmap to which we refer. In any case, this is a very limited set of operations, affecting a small group of users.

A deployment report of the NBE dated 30/03/2023 is attached.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/58

In relation to the number of users served by Electronic Banking and the modes of access:

(...)

Regarding the chronology of events. Actions taken to minimize adverse effects and measures adopted for final resolution

In the Security Incident Analysis Report accompanying the breach notification form, it is noted:

(...)

From the RSI areas responsible for fraud and the development of the NBE, the investigation begins to understand how the fraud occurred.

(...)

1. The mitigating measures carried out during December 7 and 9 were:

(...)

Regarding the causes that made the breach possible

(...)

Regarding the affected data

The information that may have been accessed during the breach includes personal, contact, and financial data:

(...)

In the Security Incident Analysis Report accompanying the breach notification form, the type of information that has been extracted by the cybercriminal and the impact on individual clients is analyzed, taking into account, among others, the following variables:

(...)

During the course of the investigation actions, additional information is requested from RSI regarding the data of clients who do not have an Electronic Banking Agreement that the users involved in the breach may have accessed. In its response, RSI states that:

(...)

The following personal and contact data are listed:

(...)

Regarding the data processing agreement

RSI provides the Treatment Activities Registry of RSI and indicates that the processing where the Electronic Banking operation is located is the Client Management processing, where RSI acts as the processor.

RSI provides the Agreement for the modification of the data protection clause of the service provision contracts signed between, CAJA RURAL DE JAÉN,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/58

BARCELONA AND MADRID, S.C.C. (data controller), and RSI (data processor).

RSI states that this Agreement was signed with the Entities in 2018 and that it is the same model for all of them.

The Agreement includes, among other aspects:

- The purpose of the Agreement is to establish the legal regime applicable to the processing of personal data that is processed or may be processed by the data processor, under the service provision contracts that are signed between the parties, and which are under the ownership and control of the data controller.
- The data processor is obliged to process the data in accordance with the instructions of the data controller.
- The data processor shall apply technical and organizational security measures to ensure an adequate level of security.
- The data processor is authorized to subcontract the companies reflected in Annex A of the Agreement – Subcontracting. The subcontractor, who also has the status of data processor, is also obliged to comply with the obligations established in the Agreement for the data processor and the instructions issued by the data controller.

Regarding the security measures

RSI indicates that the planning for the development of the NBE extends from 2019 to 2022 and that during December 2019, a risk analysis of the NBE was conducted for both the Web version and the App. The following areas were analyzed:

(...)

Regarding the Customer Management processing, RSI indicates that a data protection risk analysis has been carried out by the Data Protection Officer. This analysis is conducted with an initial review of the list of threats and the assessment of whether they apply to the processing or not, provides the threat assessment questionnaire, and a second part, where the risk analysis is performed according to RSI's risk analysis methodology. The result of this analysis is provided.

RSI indicates that, (...) and that in compliance with this line of work, three security evaluations have been conducted on Ruralvía Clásica, the reports of which are provided:

- Report prepared by the company ***COMPANY.1, dated 28/02/2022.
- Report prepared by the company ***COMPANY.1, dated 28/04/2022.
- Report prepared by the company ***COMPANY.2, continuous evaluation reflecting the tests conducted between 01/10/2021 and 30/04/2023, where all critical vulnerabilities are closed.

The report prepared by the Cybersecurity department of RSI is also provided, which lists the three security evaluations conducted by a third party and the status of the resolution of the detected vulnerabilities.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

6/58

Additionally, RSI certifies that, (...) by an external provider. It attaches the audit report and states: RSI, in its submission dated 1/10/2023 to the AEPD, explains:

(...)

It also lists the audits that have been conducted subsequent to those mentioned in the previous information requests in compliance with the fraud plan:

(...)

Likewise, (...) to comply with the Delegated Regulation (...) with the audited period from 15/12/2021 to 15/12/2022. The Report is dated 15/12/2022.

Specifically, it focused on reviewing the information associated with the security measures related to the enhanced authentication measures across the various channels and payment services offered by RSI. The Audit Report conducted by the firm ***COMPANY.3 is provided.

To address the detected vulnerabilities in accordance with the compliance level with ***STANDARD.1, an action plan is implemented by RSI. The Action Plan with the current status is provided.

(...)

Technical and organizational measures adopted to avoid, as much as possible, incidents like the one that occurred.

In addition to the measures described above, RSI conveys that:

(...)

RSI, in its submission dated 11/10/2023 to the AEPD, details the operation of these controls:

(...)

Throughout February 2023, the following actions were carried out:

(...)

Regarding the communication to the affected parties,

9 entities, including CAJASALAMANCA, have communicated the breach to all affected customers who have an Electronic Banking Agreement.

Another 10 entities of the Group have communicated the breach to all affected customers.

And another 7 have not communicated the breach to the affected customers who are individuals:

The model of communication to the affected parties regarding the breach is provided, including the contact details of the DPO of the Entity and describing the possible consequences of the incident for the affected parties.

Information on the recurrence of these events and the number of analogous events that have occurred over time.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/58

RSI states that these events are not recurrent, being this the first occasion they have occurred.

It also indicates that they have not received any news from their Cyber Threats service regarding the publication of data on the dark web.

THIRD: On 22/01/2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against CAJASALAMANCA for the alleged violations of Articles 5.1.f), 32.1, and 33.1 of the GDPR, classified under Articles 83.5.a) and 83.4.a) of the GDPR.

This initiation agreement, which was notified to CAJASALAMANCA in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was recorded on 23/01/2024, as evidenced by the acknowledgment of receipt in the file.

FOURTH: After the initiation agreement was notified, CAJASALAMANCA requested by written communication dated 30/01/2023 a copy of the documents that made up the administrative file and an extension of the deadline to submit allegations and propose relevant evidence.

By written communication dated 05/02/2024, the instructor extended the deadline for submitting allegations by a maximum of ten days, calculated from the day after the receipt of the copy of the file. On 26/02/2023, the instructor of the file sent a written communication to the data processor indicating that "Since a large part of the documentation in the file has been provided by RSI through the General Electronic Registry, the registration numbers of the submitted documents were grouped by dates, so that within 10 working days, they could communicate whether there were documents, or parts of documents, that they considered should not be provided to the respondent party, due to reasons related to commercial secrecy, personal data protection, or others."

On 11/03/2024, the data processor stated "that regarding its transfer to the respondent party, my client considers that it does not correspond to them, but to the AEPD to assess the legality of such transfer and/or, if applicable, the existence of any impediments or limitations that may be established by the applicable regulations."

On 10/04/2024, the instructor of the procedure sent two written communications to the respondent party: one, providing a copy of the administrative file in accordance with the provisions of Article 53.1 a) of the LPCAP and, separately, a second one in which the key and hash were provided that would allow access to the documentation included in the physical support.

On 25/04/2024, CAJASALAMANCA submitted a written statement of allegations summarizing the following:

- That all procedures (26) opened against the entities belonging to the Caja Rural Group be accumulated due to the close connection and substantial identity; the absence of culpability of the respondent party in the present case;
- The impact on the principles of sanctioning law as a consequence of the interpretation made by the AEPD;
- Non-existence of a violation of Article 32.1 of the GDPR;
- Non-existence of a violation of Article 5.1.f) of the GDPR;
- Non-existence of a violation of Article 33 of the GDPR;
- Violation of the principle of proportionality in determining the sanctions;
- That the proceedings be archived or a warning sanction or a significant reduction of the sanction be agreed upon.

FIFTH: On 21/10/2024, it was agreed to open a period for the practice of evidence, agreeing on the following:

- To consider the complaint filed by the complainant and its documentation as reproduced for evidentiary purposes, along with the documents obtained and generated by the Inspection Services that are part of the file.
- To consider the allegations to the initiation agreement presented by the respondent as reproduced for evidentiary purposes, along with the accompanying documentation.
- To request the respondent party to provide documentation proving that, if applicable, they had instructed their data processor to notify the AEPD of the personal data breach subject to this sanctioning file and the accreditation of both the aforementioned instruction and the terms contained therein, along with the date of the same.

On 05/11/2024, the respondent party responded to the evidence practiced, the content of which is included in the file.

SIXTH: Attached as an annex is a list of documents in the procedure.

From the actions taken in this procedure, the following have been established,

PROVEN FACTS

FIRST:

As stated in the deed of elevation to public of social agreements granted by CAJA RURAL DE SALAMANCA, S.C.C., dated 22/12/2006, (...).

It is governed by the provisions of its Statutes and, in matters not provided for therein, by Law 13/1989, of May 26, on Credit Cooperatives, its development regulations, and other provisions that, in general, regulate the activity of credit entities, applying the cooperative legislation as supplementary.

Furthermore, as provided in its Statutes, it enjoys its own legal personality and full capacity to act.

SECOND:

On 25/04/2023, CAJASALAMANCA submitted, along with the written statement of allegations to the initiation agreement, the "Agreement to modify the data protection clause of the service provision contracts signed between CAJASALAMANCA and RSI dated 18/09/2018 and signed on behalf of CAJASALAMANCA by A.A.A..

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/58

In this Agreement it is specified:

"ON ONE SIDE, CAJASALAMANCA (hereinafter, Data Controller),

(...)

AND

ON THE OTHER SIDE, RSI (hereinafter, Data Processor),

(...)

In this agreement it is stated that,

"The purpose of the Agreement is to establish the legal framework applicable to the processing of personal data that may be processed by the data processor, by virtue of the service contracts that are signed between the parties, and which are under the ownership and control of the data controller.

The data processing activities foreseen are those strictly necessary for the provision of the services provided in the main contract. The processing activities that could be carried out by RSI, the type of information to be processed, and the categories of data subjects whose data could be processed are defined."

In the Agreement itself, it is indicated in section 3, relating to the Obligations of the Data Processor, that:

"The Data Processor and all its personnel are obliged to:

- a) Use the personal data subject to processing, or those collected for its inclusion, only for the purpose

of this assignment. Under no circumstances may the data be used for any other purpose, whether for its own or for third parties. To carry out any other activity aimed at the processing or use of the data files of the Data Controller, prior written consent from the Data Controller will be necessary.

b) Process the data in accordance with the instructions of the Data Controller.

(...)"

Regarding the notification of "data security breaches," it is specified in section 3.3 that:

"The Data Processor shall notify the Data Controller, without undue delay, and in any case, before the maximum period of 36 hours, and through the DPO, of any data security breaches concerning personal data under its responsibility of which it becomes aware, along with all relevant obligations for the documentation and communication of the incident.

(...)"

Section 3.4 regarding security measures adds that:

"The Data Processor, in accordance with the provisions of Article 32, shall implement those technical and organizational measures appropriate to ensure a level of security adequate to the risk of processing detected in each case, considering the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probability and severity risks to the rights of individuals at any given time.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/58

In any case, it must implement mechanisms equivalent to those used by the Data Controller to:

- a. Ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services.
- b. Restore the availability and access to personal data quickly in the event of a physical or technical incident.
- c. Regularly verify, evaluate, and assess the effectiveness of the technical and organizational measures implemented to ensure the security of processing.
- d. Pseudonymize and encrypt personal data, where applicable.

The technical and organizational measures to be implemented by the Data Processor are reflected in Annex B of this agreement - Security Measures.

The Data Processor is authorized to subcontract the companies reflected in Annex A of the Agreement – Subcontracting. The subcontractor, who also has the status of Data Processor, is equally obliged to comply with the obligations established in the Agreement for the Data Processor and the instructions issued by the Data Controller.

Regarding the obligations of the Data Controller, it is indicated in section 4 of the Agreement:

"It is the responsibility of the Data Controller:

- a) To provide the Data Processor with the necessary data for the provision of the service.
- b) If legally required, to carry out a data protection impact assessment of the processing operations to be carried out by the Data Processor.
- c) To carry out the necessary prior consultations.
- d) To ensure, prior to and throughout the processing, compliance with the GDPR by the Data Processor.
- e) To supervise the processing, including conducting inspections and audits."

In section 5, the DPO of the Data Processor and the Data Controller are identified respectively.

Regarding CAJASALAMANCA (...):

"Identification B.B.B.

Contact ***EMAIL.1."

Regarding RSI (...):

"Identification C.C.C.

Contact ***EMAIL.2."

Section 6 of the Agreement provides for “Liability” that,
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/58

“If the Processor, or in its case, the contractors, violate this Agreement or the applicable regulations when determining the purposes and means of processing, they will be considered responsible for the processing concerning such processing.

In the event that a supervisory authority sanctions the Data Controller as a direct consequence of the Processor's failure to comply with the stipulations of this Agreement, the Processor shall indemnify the Data Controller as stipulated in the liability clause of the framework contract in force between the parties.”

THIRD:

In the “Agreement to Modify the Data Protection Clause of Service Provision Contracts,” signed between CAJASALAMANCA and RSI, signed in Madrid on 18/09/2018, Annex B - Security Measures to the Agreement to Modify the Data Protection Clause of Service Provision Contracts indicates that RSI holds the following certifications:

(...)

Likewise, in the “Agreement to Modify the Data Protection Clause of Service Provision Contracts,” it is indicated that RSI has the following measures:

(...)

FOURTH:

On 13/12/2022, a personal data breach of CAJASALAMANCA was reported to the Division of Technological Innovation of this Agency, with entry number REGAGE22e00057114539. This notification was sent by RSI, the data processor of CAJASALAMANCA. Attached to this notification is the “Security Incident Analysis Report.”

On 10/01/2023, CAJASALAMANCA made an additional notification to that described in the previous section, with entry number REGAGE23e00001622191.

On 13/12/2022, a personal data breach was reported to the Division of Technological Innovation of this Agency, with entry number REGAGE22e00057114539. This notification was sent by the entity belonging to the GRUPO CAJA RURAL: CAJASALAMANCA, with NIF F37015856 as the data controller.

FIFTH:

CAJASALAMANCA had the electronic banking application called Ruralvía Clásica for the purpose of providing online banking services to its clients.

CAJASALAMANCA wanted to change this application to a new electronic banking application called Nueva Banca Electrónica (NBE).

(...)

On 14/04/2023, in response to the request made by the AEPD, RSI states that:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

12/58

(...)

SIXTH:

Regarding the establishment of a banner in the Ruralvía Clásica application that linked to the new NBE application and its operation, in the “Security Incident Analysis Report,” dated 9 December 2022, which RSI provided in relation to the personal data breach of CAJASALAMANCA, it is indicated:

(...)

Likewise, on 14/04/2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, RSI responds that:

(...)

SEVENTH:

(...)

On 14/04/2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, a document 9 titled "Web Application Audit" was submitted, indicating (...).

EIGHTH:

(...)

NINTH:

Regarding how the personal data breach occurred, on 14/04/2023, RURALVÍA, in response to the information request made by this Agency, states the following,

(...)

Likewise, in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASALAMANCA, it is indicated in section 1.4.2, "How was the problem detected or how did it happen?" that:

(...)

TENTH:

Likewise, in the "Final Security Incident Analysis Report," dated 30/12/2022, which RSI provided in relation to the personal data breach of CAJASALAMANCA, in section 1.4.1, "What happened?" it is indicated that the personal data breach occurred due to a vulnerability in the SSO system, stating that:

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/58

ELEVENTH:

Regarding the attack pattern used by the cybercriminal, on 14/04/2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, RSI indicates that,

(...)

The same provision is contained in section 1.4.2 of the "Final Incident Analysis Report," dated 30/12/2022, which RSI submitted in relation to the personal data breach of CAJASALAMANCA.

TWELFTH:

Regarding the causes that allowed the personal data breach, in the "Final Incident Analysis Report," dated 30/12/2022, which RSI submitted in relation to the personal data breach of CAJASALAMANCA, it is stated in section 3, "Cause Analysis," that:

(...)

THIRTEENTH:

In response to the information request made by the AEPD within the framework of the preliminary investigation proceedings, RSI responds on 26/05/2023 by providing as document 8 an email dated 28/09/2022, prior to the increase in access volume (between November 10 and 23 of the same month) and the detection of the personal data breach, sent by (...).

In the same vein, as indicated, on 14/04/2023, responding to the request made by the AEPD within the framework of the preliminary investigation proceedings, RSI responds that,

(...)

On April 14, 2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, document 9 titled "Web Application Audit" was submitted, indicating that,

(...)

FOURTEENTH:

On 14/04/2023, in response to the request made by the AEPD within the framework of the preliminary investigation proceedings, document 9 titled "Web Application Audit" was submitted, which examined ***TOOL.1.

(...)

FIFTEENTH:

Regarding the detection of the personal data breach, in the "Final Incident Analysis Report," dated 30/12/2022, which RSI submitted in relation to the personal data breach of CAJASALAMANCA, it is stated in section 1.4.1, "What happened?", that:

(...)

Therefore, although the breach was detected on December 7, 2022, prior accesses to that date are confirmed, noting that the highest volume of accesses occurred between November 10 and November 23, 2022.

Regarding the measures adopted on November 23, 2022, the aforementioned document indicates that,

(...)

Therefore, these measures were adopted before the personal data breach was detected (on December 7, 2022) and as a result of actions to enhance the security of online banking.

SIXTEENTH:

Regarding the mitigating measures applied after the personal data breach, in the "Final Incident Analysis Report," dated 30/12/2022, which RSI submitted in relation to the personal data breach of CAJASALAMANCA, it states that,

(...)

SEVENTEENTH:

Subsequently, within the framework of the definitive implementation of the new NBE application, a series of actions are carried out, as noted in the "Final Incident Analysis Report," dated 30/12/2022, which RSI submitted in relation to the personal data breach of CAJASALAMANCA, that,

(...)

EIGHTEENTH:

Regarding the personal data accessed by the attacker, in the "Final Incident Analysis Report," dated 30/12/2022, which RSI submitted in relation to the personal data breach of CAJASALAMANCA, it indicates which personal data may have been accessed,

(...)

NINETEENTH:

The breach notification forms that accompany the Security Incident Report prepared in all cases by RSI, the data processor, as stated in the preliminary investigation report of November 27, 2023, determine that the number of affected individuals by the personal data breach of CAJASALAMANCA is 1,183 clients.

TWENTIETH:

During the evidence gathering period referred to in the Tenth Background, CAJASALAMANCA provided an email sent to the data processor, RSI, regarding the notification of the personal data breach to the AEPD:

(...)

(...)

we give our consent to submit the notification to the AEPD as data processors, on behalf of the Entity. On the other hand, regarding the communication to the clients affected by the security breach, we await the model of communication that would be sent to the clients for review. Therefore, we request that the incident not be communicated to the interested parties until further notice.

(...)

TWENTY-FIRST:

According to the diligence dated 19/01/2024 in the file, the business volume (gross margin) of CAJASALAMANCA during the year 2022 amounts to 24,697,000 euros.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), it is competent to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/58

to initiate and resolve this procedure the Director of the Spanish Agency for Data Protection.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development and, in so far as they do not contradict them, subsidiarily, by the general rules on administrative procedures."

II

Preliminary Issues

In the case examined, in accordance with the provisions of Article 4.1 of the GDPR, it is established that personal data processing is taking place, since CAJASALAMANCA carries out, among other things, the collection and storage of personal data of both natural and legal persons, its clients, (...). The entity carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means related to the processing of personal data, by virtue of Article 4.7 of the GDPR. Thus, if it decides the "why" and the "how" personal data should be processed, it must assume its responsibility.

Moreover, the data controller must also be responsible for applying the technical and organizational measures that ensure the security of personal data when carrying out the processing. And must be able to demonstrate compliance with the GDPR and the LOPDGDD.

On its part, Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that lead to the accidental or unlawful destruction, loss, alteration of personal data transmitted, stored or otherwise processed, or unauthorized communication or access to such data."

In the present case, there is a security incident, categorized as a personal data breach, having occurred an unauthorized access to personal data.

It should be noted that the identification of a personal data breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the controllers and processors and the security measures applied.

Among the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in paragraph 1.f).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/58

On its part, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which regulate the security of processing, notification to the supervisory authority, as well as communication to the data subject, respectively.

As previously mentioned, it is presumed that the data controller is the entity that has the true capacity to exercise control over the data, who determines the why and how the data should be processed.

On the other hand, according to the diligence dated 19/01/2024 in the file, the turnover (gross margin) of CAJASALAMANCA during the 2022 financial year amounts to 24,697,000 euros.

III

Description of the personal data breach

CAJASALAMANCA had the electronic banking application called Ruralvía Clásica for the purpose of providing online banking services to its clients.

For a client to enter the Ruralvía Clásica application and log in, they needed to enter their identifier, password, and NIF.

CAJASALAMANCA wanted to change that application to a new electronic banking one, called Nueva Banca Electrónica (NBE).

(...)

IV

Unfulfilled obligation: violation of Article 5.1.f) of the GDPR.

Article 5.1.f) "Principles relating to processing" of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in such a way as to ensure an adequate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

(...)

Thus, as stated in the nineteenth proven fact, regarding the personal data to which the attacker had access, in the "Security Incident Analysis Report Final Report," dated 30/12/2022, it indicates that,

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/58

Although the personal data breach was detected on 07/12/2022, previous accesses to that date were confirmed, with the highest volume of accesses occurring between 10 November and 23/11/2022.

In this regard, in the aforementioned report dated 30/12/2022, as stated in the proven facts eighth and fourteenth, it is indicated in section 1.4.2, "How was the problem detected or how did it happen?", that:

(...)

The attacker was able to access those personal data of CAJASALAMANCA customers due to the lack of appropriate technical and organizational measures prior to the occurrence of the personal data breach.

First, it should be noted that, as stated in the proven fact eleventh, regarding the causes that allowed the personal data breach, in the "Final Incident Analysis Report" dated 30/12/2022, in section 3, "Cause Analysis", it states:

(...)

Secondly, in the proven fact fifteenth, the mitigating measures implemented are recorded, which highlight the absence of appropriate technical and organizational measures to prevent the occurrence of the breach, emphasizing, for such purposes,

(...)

In conclusion, and in accordance with all the above, it has been established that the violation of the principle of confidentiality that indeed occurred, as the attacker accessed multiple personal data of CAJASALAMANCA customers, was possible due to the lack of appropriate technical and organizational measures highlighted by the aforementioned vulnerabilities.

The number of affected customers of the entity due to the breach amounts to a total of 1,183 users, with 1,134 having been notified of the security incident that occurred.

(...), which made them have an additional impact by being able to access their economic data.

The documentation in the file provides clear evidence that CAJASALAMANCA violated Article 5.1.f) of the GDPR, "Principles relating to processing," by not properly ensuring the confidentiality and integrity of personal data as a result of the personal data breach that occurred.

In accordance with the evidence available in this proposal for the resolution of the sanctioning procedure, it is considered that the known facts constitute an infringement, attributable to

CAJASALAMANCA, for violation of Article 5.1.f) of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/58

V

Classification for the infringement of Article 5.1.f) of the GDPR

In accordance with the evidence available and without prejudice to what results from the instruction, it is considered that CAJASALAMANCA did not properly guarantee the confidentiality and integrity of personal data.

The infringement attributed to the entity is classified in Article 83.5 a) of the GDPR, which states that the infringement of "the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9" is punishable, in accordance with paragraph 5 of the aforementioned Article 83 of the cited Regulation, "with administrative fines of up to €20,000,000 or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount."

The LOPDGDD in its Article 71, Infringements, states that: "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 constitute infringements, as well as those that are contrary to this organic law."

And in its Article 72, it considers for the purposes of prescription that they are: "Infringements considered very serious:

1. According to what is established in Article 83.5 of Regulation (EU) 2016/679, those infringements that involve a substantial violation of the articles mentioned therein are considered very serious and will prescribe in three years, particularly the following:

(...)

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679.

(...)"

VI

Proposal for sanction for the infringement of Article 5.1.f) of the GDPR

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures provided for.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

20/58

in Article 58, paragraph 2, letters a) to h) and j)). When deciding on the imposition of an administrative fine and its amount in each individual case, the following will be duly taken into account:

a) the nature, seriousness, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the data controller or processor to mitigate the damage and harm suffered by the affected parties;

d) the degree of responsibility of the data controller or processor, taking into account the technical or

organizational measures they have implemented under Articles 25 and 32;

e) any previous infringement committed by the data controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate any potential adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor reported the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with those measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits obtained or losses avoided, directly or indirectly, through the infringement.

In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, "Sanctions and corrective measures," establishes that:

"2. According to the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The continued nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in those cases."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/58

"assumptions in which there are controversies between them and any interested party."

In accordance with the transcribed provisions, for the purpose of determining the amount of the sanction to be imposed in this case for the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the GDPR for which CAJASALAMANCA is held responsible, the following factors are deemed concurrent:

- The nature, severity, and duration of the infringement; the facts revealed affect a basic principle related to the processing of personal data, such as confidentiality and integrity, which the regulation penalizes with the utmost severity as it allows, as a consequence of the personal data breach, unauthorized third parties to access personal data, with the harm that this may entail.
- The number of affected interested parties: it is very high (...), which placed them in a position of special impact as the attacker could access their economic data.
- Regarding the level of damages and losses caused: it must be considered (...), economic and financial data must be added since users who had access to Electronic Banking would have been able to access this type of data (...). Additionally, it should be noted that this situation enables access to the data, and thus the risk of identity theft may materialize, among others (Article 83.2.a) of the GDPR).
- The intentionality or negligence in the infringement. There is a lack of diligence in complying with the obligations imposed by data protection regulations, allowing access by cybercriminals to personal data, thereby violating its confidentiality; in this regard, the SAN of 17/10/2007 can be cited, which, although issued before the GDPR came into force, its ruling is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activities involve continuous

processing of customer and third-party data must observe an adequate level of diligence, specified that "(...) the Supreme Court has understood that there is recklessness whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard" (Article 83.2.b) of the GDPR).

- The activity of the allegedly infringing entity is linked to the processing of personal data of both clients and third parties. In the activity of the summoned entity, it is essential...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/58

processing of personal data, given its object and business volume, the significance of the conduct subject to this claim is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

For the purpose of deciding on the proposal for the fine and its amount, in accordance with the available evidence, taking into account the criteria of Article 83.2 of the GDPR regarding the infringement committed, violation of Article 5.1.f) of the GDPR, it is considered appropriate to propose a sanction of 250,000 euros.

VII

Violation of Article 32.1 of the GDPR.

Article 32 of the GDPR "Security of processing" establishes that:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law."

After reviewing the allegations made by CAJASALAMANCA, and in consideration of them, reviewing the documentation in the administrative file and the documentation provided by the respondent party, it is evident that all the technical and organizational security measures whose absence has been proven, directly enabling the personal data breach, have not resulted in a violation, in this specific case, of Article 32 of the GDPR as the absence of other independent technical and organizational security measures unrelated to the personal data breach has not been demonstrated.

VIII

Violation of Article 33.1 of the GDPR

Article 33 of the GDPR, "Notification of a personal data breach to the supervisory authority," establishes that,

"1. In the case of a personal data breach, the controller shall notify the competent supervisory authority in accordance with Article 55 without undue delay and, where feasible, no later than 72 hours after having become aware of it, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification to the supervisory authority does not take place within 72 hours, it shall be accompanied by the reasons for the delay.

2. The processor shall notify the controller without undue delay of any personal data breaches of which it becomes aware.

3. The notification referred to in paragraph 1 shall, at a minimum:

a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of data subjects affected, and the categories and approximate number of personal data records affected;

b) communicate the name and contact details of the data protection officer or another contact point where more information can be obtained;

c) describe the possible consequences of the personal data breach;

d) describe the measures taken or proposed by the controller to remedy the personal data breach, including, where appropriate, the measures taken to mitigate its possible adverse effects.

4. If it is not possible to provide the information simultaneously, and to the extent that it is not possible, the information shall be provided in phases without undue delay.

5. The controller shall document any personal data breaches, including the facts relating to the breach, its effects, and the remedial measures taken. This documentation shall enable the supervisory authority to verify compliance with the provisions of this article."

On 21/10/2024, it was agreed to open a period for the practice of evidence in which point 3: It is agreed to require CAJASALAMANCA to provide the following information and/or documentation:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/58

"That you provide documentation proving that, if applicable, you had instructed or given orders to your data processor for the notification to the AEPD of the personal data breach subject to this sanctioning procedure. Accreditation of both the aforementioned order and the terms contained therein, as well as the expression of the date of the same."

The requested party has submitted in response to this requirement on 05/11/2024, the following documents:

Document number 1: Email dated 13/12/2022, where RSI, in its capacity as data processor for CAJASALAMANCA, communicated the security incident to the latter, indicating that they were preparing a report regarding it, indicating next steps (notification to the AEPD and communication to the affected parties) and requesting validation from CAJASALAMANCA as the data controller.

Document number 2: Email dated 13/12/2022, from CAJASALAMANCA to RSI in which "the consent to submit the notification to the AEPD as data processors, on behalf of the Entity" is given.

Document number 3: Email dated 13/12/2022, in which RSI states, "Attached to this email is the proof of notification to the Spanish Agency for Protection regarding the security incident suffered."

After analyzing the documentation submitted by CAJASALAMANCA referred to in the twentieth proven fact, it is determined that the investigated party has provided, in response to the evidence gathering carried out by this Agency regarding the accreditation of the instructions given to its data processor, for it to proceed with the notification on its behalf to the AEPD of the personal data breach subject to the aforementioned procedure, in accordance with Article 33 of the GDPR.

Therefore, it must be concluded that, after analyzing the investigated facts, the allegations made by CAJASALAMANCA, and the evidence provided in the procedure, considering the circumstances present in the specific case, the filing of the alleged infringement in relation to Article 33 of the GDPR

would be appropriate.

IX

Response to the allegations made regarding the initiation agreement

In relation to the allegations made by CAJASALAMANCA regarding the initiation agreement, we proceed to respond to them in the order they are presented in their writing:

FIRST. ON THE ACCUMULATION OF THE PROCEDURES TO THE ENTITIES OF THE GROUP.

1. Preliminary considerations

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/58

According to CAJASALAMANCA: "All the initiation agreements in the files that have just been referenced arise, as indicated, from the security breach analyzed by the Initiation Agreement" and subsequently states that "we are faced with a single fact, referring to a single breach, suffered during the development of the aforementioned tool carried out by RSI in its capacity as data processor and which, however, is fragmented by the AEPD into twenty-six differentiated procedures processed against twenty-six different entities."

In response to these preliminary considerations, it should be noted that the requested party confuses the factors that determined the vulnerability being similar in all the procedures initiated by this Agency with the fact that only a single personal data breach has occurred.

We are dealing with incidents that have affected 26 entities that are completely independent, both legally and economically. Each of these entities is responsible for the data processing of their clients in a differentiated manner, and, consequently, there are as many personal data breaches as there are data controllers who have failed to comply with the obligations imposed by the GDPR. Each entity is responsible for the processing of its own data and regarding its own clients.

All the entities referred to by the requested party in their allegations had contracted with RSI, (...).

However, the fact that RSI was the same data processor for all the Entities does not determine that one can speak of "a single fact, referring to a single breach."

Each entity, as the data controller of its clients, autonomously made the decision to contract with RSI as the data processor, for which each of them signed their own data processing agreement, on different dates, signed by different persons with sufficient power for this in each of the rural banks and with reference to their different data protection delegates, who are not the same.

Furthermore, as also stated in the proven facts, both the "Security Incident Analysis Report," dated 09/12/2022, and the "Final Security Incident Analysis Report," dated 30/12/2022, were carried out individually for each of the rural banks, containing their own specificities.

Likewise, once the personal data breach occurred, the actions of each of the entities were not the same, with each acting autonomously, both in relation to the AEPD (some banks notified the personal data breach directly and others entrusted their data processor to carry it out), as well as with their respective clients and independently of the actions of the others.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/58

2. On the accumulation of administrative procedure files.

In this allegation, the responding party considers that: "The legal regime of the accumulation of procedures, as well as of processes, in the administrative sphere responds to the central idea of connectivity, that is, that the instructional work that must be carried out is favored by the appreciation of the issue as a whole and the possibility that the joint viewing work allows for a better assessment of the elements that enable the application of the norm to the specific case."

Article 57 of the LPACAP on the accumulation of procedures establishes that: "The administrative

body that initiates or processes a procedure, regardless of the form of its initiation, may, ex officio or at the request of a party, order its accumulation with others that have substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure. No appeal shall proceed against the agreement of accumulation."

Consequently, both the administrative body that initiates the procedure and the one that processes it may order its accumulation with other procedures that have substantial identity or intimate connection, provided that it is the same body that must process and resolve the procedure.

Article 57 of the LPACAP grants administrative bodies the authority for better management of the procedures they process, allowing their accumulation as long as there is substantial identity or intimate connection among them. Therefore, it is a possibility available to the Administration, which is not obliged to proceed with the accumulation if requested, although it is required to decide on the matter with justification, as occurs in the present sanctioning procedure.

3. On the response to the allegation seeking the accumulation of sanctioning procedures.

In this allegation, the responding party considers that: "The legal regime of the accumulation of procedures, as well as of processes, in the administrative sphere responds to the central idea of connectivity, that is, that the instructional work that must be carried out is favored by the appreciation of the issue as a whole and the possibility that the joint viewing work allows for a better assessment of the elements that enable the application of the norm to the specific case."

It should be noted that the claims of the responding party are not supported by Article 57 of the LPACAP, nor by any type of jurisprudence or doctrine, in which the purpose of accumulation is attributed to providing the decision-making body with a better assessment of the elements of the case. The institution of accumulation is a technique of administrative simplification that allows the competent body to process and resolve in a main procedure the possibility of accumulating with those others that have substantial identity or intimate connection, for the purposes of simultaneous processing and resolution. The instrumental nature of accumulation is determined by the...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
27/58

The first limit established by Article 57 of the LPACAP is that the body "must be the same body that processes and resolves the procedure."

This is a procedural act that cannot be challenged, as established by Article 57 of the LPACAP itself, unlike what is provided in Article 112.1 of the same regulation, which does allow for the challenge of other procedural acts when they "directly or indirectly decide the substance of the matter, determine the impossibility of continuing the procedure, produce defenselessness, or cause irreparable harm to legitimate rights and interests."

However, when the LPACAP excludes the possibility of appeal, it is because it applies to the accumulation of procedures, as a procedural act, none of the cases in Article 112.1 of the LPACAP that we have just reproduced.

With these arguments as a starting point, the allegations made by the responding party must be completely dismissed, to which a specific response will also be provided.

A) Existence of "intimate connection" or "substantial identity."

The responding party reiterates the idea referred to in the preliminary considerations of this FIRST allegation, stating that "a single breach of personal data security occurred, notified by each of the responsible parties (directly or through their data processor RSI)." It continues to assert that "the connectivity, in this case, arises from the fact that responsibility is to be clarified for twenty-six legal entities, but for the same fact."

As already substantiated in the response to the preliminary considerations of this FIRST allegation, it cannot be said that there is a single breach of personal data security; rather, there have been as many breaches of personal data security as there are entities, all of which are independent of each other, each responsible for its own processing and regarding its own clients, whose systems have suffered a security breach.

For the investigated party, there is a single fact upon which responsibilities can be demanded, the security incident in the field of information technology. However, beyond the breach of personal data itself, there has been a loss of confidentiality of the personal data of the clients of each of the entities, which cannot be encompassed as a single fact or as the same fact.

In the same way, the facts related to the actions following the knowledge of the security breach by each of the entities must be differentiated. Some entities directly notified the AEPD of the breach, while in others, the communication was made by the data processor at the request of each of the data controllers (in different ways and at different times).

Finally, some entities communicated the loss of confidentiality of their personal data to the affected parties, fulfilling the obligation established in Article 34 of the GDPR, while other entities did not send any type of communication.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
28/58

All diverse factual elements determine that it cannot be said that, beyond the same cybersecurity vulnerability, there exists an "intimate connection" or "substantial identity" that justifies the accumulation of the proceedings. Regarding the ruling of the TSJ Castilla-La Mancha cited in the allegations, the following clarifications should be made:

1) There is no fulfillment of an obligation by several persons jointly, so the assumption of Article 28.3 of Law 40/15 does not apply. According to Article 28.3 of Law 40/2015, of October 1: "When the fulfillment of an obligation established by a norm with the rank of Law corresponds to several persons jointly, they will be jointly liable for the infringements that may be committed and for the sanctions that are imposed. However, when the sanction is monetary and it is possible, it will be individualized in the resolution based on the degree of participation of each responsible party."

In the present case, one cannot speak of the existence of joint liability, as it is not a joint obligation of CAJASALAMANCA with the other entities referred to in its written allegations. The facts constituting the infringement attributed to CAJASALAMANCA are so in its capacity as the data controller, in accordance with the provisions of Article 4 of the GDPR, so that the fulfillment of the principles and obligations established in the GDPR regarding the data processing of its clients corresponds to it individually, not jointly with the other entities, since, furthermore, there is no joint liability in the GDPR. It should be noted that the fine imposed on each entity depends on its own circumstances, such as the number of affected clients or its business volume.

The figure of joint controllers of processing, regulated in Article 26 of the GDPR, would also not apply in this case, "when two or more controllers jointly determine the purposes and means of processing, they will be considered joint controllers of processing." The purposes and means of processing have been determined by CAJASALAMANCA independently of the other entities, in its capacity as the sole data controller of the personal data of its clients.

Finally, the assumption described in the ruling does not apply to CAJASALAMANCA in relation to the other entities, in which "the Administration imputes different forms of cooperation or collusion among the three defendants in relation to the same facts." Here, there can be no talk of any type of cooperation or collusion in the facts, simply the responsibility of each of the Rural Banks, and the relationship with the data processor, due to the regime established in the GDPR.

2) The separate processing of the files does not prevent each entity from presenting its allegations.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
29/58

In the ruling of the TSJ of Castilla La Mancha referred to by CAJASALAMANCA, in the Third Legal Foundation, it is stated that the plaintiff requested that all proceedings be consolidated in order to adequately exercise the right of defense, "...since they referred to the same facts, and it was expressly

noted that processing them separately would constitute a serious violation of the right of defense as it would prevent knowledge of the allegations of the other parties involved and the documents they might submit, all of which could have implications for the legal qualification of the facts, the determination of the existence or non-existence of an infringement, and the identification of the responsible party.” The non-consolidation of proceedings cannot produce any of the harms outlined in that paragraph of the ruling.

Regarding the documents submitted to the procedure, those relating to the security incident, a series of documents were provided by the data processor during the investigative proceedings (let us remember that both the “Security Incident Analysis Report,” dated 09/12/2022, and the “Final Security Incident Analysis Report,” dated 30/12/2022, were prepared individually for each of the rural banks, containing their specific characteristics), access to which has been guaranteed to all affected entities through the sending, upon request, of a copy of the file. Those documents submitted by the entities responsible for processing, which affect them individually, will be taken into consideration in the corresponding procedure.

3) CAJASALAMANCA reiterates the need for the “consolidated analysis of the files,” when the ruling of the TSJ of Castilla La Mancha does not include this idea. The need for consolidation is based on considerations other than those expressed by CAJASALAMANCA. As we have analyzed:

- Reference is made to access to the documents in the file that may be submitted by different responsible parties, a matter that we see is guaranteed here.
- The possibility of establishing joint liability is mentioned, which, as we have substantiated, does not apply under the regime established in the GDPR. We must not confuse the joint liability of Article 28 of the LRJSP with the co-responsibility of Article 26 of the GDPR, which also does not apply in this case, since, as we stated, in no case are the other Rural Banks co-responsible for the processing of customer data of the other entities.
- There is no type of cooperation or collusion among the different Rural Banks in the facts. These figures must be dismissed due to the relationship between the Rural Banks, which are independent entities, each responsible for the processing of their customers, nor, as we have previously stated, regarding the special regime established by the GDPR concerning the responsible party-data processor relationship.

B) That the same body is responsible for the processing and resolution of the procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

30/58

The processing of the various sanctioning procedures corresponds to the same body, as stated by CAJASALAMANCA, which does not determine the mandatory nature of the decision to consolidate the procedures, especially when there are no circumstances that imply the defenselessness of CAJASALAMANCA.

4. Connectivity in the sanctioning field with the guarantees of Articles 24 and 25.1 of the Spanish Constitution.

In this allegation, CAJASALAMANCA points out that the Constitutional Court has declared that both the substantive principles of Article 25.1 CE and the procedural guarantees of Article 24.2 CE are applicable, with certain nuances, to the exercise of sanctioning power.

4.1. General aspects related to the instruction and its essential functionality.

A) Linkage of the instruction as a consequence of the factual unity.

CAJASALAMANCA cites a ruling from the Supreme Court, which states that “the initiation of a single sanctioning procedure for the commission of the same infringing act, with the aim of determining the degree of participation of each alleged responsible party in the commission of the infringement and ensuring that the resolution of the file is coherent...” According to CAJASALAMANCA, “In that case, the appellant argued that, since two files were processed, each of the responsible parties was unaware of what was in the other that could benefit or harm them. This is a concrete example of the

difficulties that arise, in terms of the right to defense, in cases of separate processing.”

As previously justified, there are as many breaches of personal data as there are data controllers, and we cannot speak of a single infringing act, but rather of a series of infringing acts attributable to a series of independent entities concerning the treatments for which they are responsible, regarding their clients; nor can we speak of “degree of participation” among the various entities, nor in terms of the responsible party-data processor relationship.

Regarding the documents that are submitted to the procedure, those that refer to the security incident, a series of documents were provided by the data processor during the investigative proceedings, whose access to all affected entities has been guaranteed through the sending, upon request, of a copy of the file. Moreover, RSI provided the “Security Incident Analysis Report,” dated December 9, 2022, as well as the “Final Security Incident Analysis Report,” dated December 30, 2022, in a manner individualized for each of the rural banks, containing their specificities.

Those documents submitted by the entities responsible for the treatment that affect them individually will be taken into consideration in the corresponding procedure. And, any other documents that could constitute evidence...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

31/58

that were relevant to the facts, will be duly incorporated into the other files ex officio, in accordance with the provisions of Article 75 of the LPACAP, “the necessary instructional acts for the determination, knowledge, and verification of the facts on which the resolution must be pronounced will be carried out ex officio.”

B) Connectivity as a fundamental prerequisite for the exercise of the right to defense.

According to CAJASALAMANCA, the break in the continuity of the case, in this instance, of the sanctioning administrative procedure implies that the two procedures become “sealed” and that the evidence, allegations, and expert opinions conducted in one cannot be presented contradictorily. However, a paragraph from the judgment transcribed by CAJASALAMANCA is fully applicable to respond to the present allegation: “it is not specified to what extent their defense had been ‘prejudiced’,” and to reject it, just as the STS understands “that the decision of the court of first instance is correct, which considers that the initiation of sanctioning proceedings against each of the companies is justified... due to the clear differentiation of the conduct attributed and the failure to demonstrate that real defenselessness had occurred - as reasoned in the contested judgment.”

The Constitutional Court in its judgment No. 210/1999, of November 29, indicates that the constitutionally relevant defenselessness is the situation in which, following the infringement of a procedural norm, one of the parties is prevented from exercising the right to defense by eliminating or limiting their power, either to assert rights and interests for them to be recognized, or to dialectically respond to opposing positions in the exercise of the principle of contracting.

As an essential characteristic of defenselessness, it must be material and not merely formal, that is, it is not sufficient for there to be a defect or procedural infringement; an effective and real right to defense must have been produced (judgment of the Constitutional Court No. 90/1988, of May 13).

Well, beyond a generic allegation of the potential defenselessness that could arise from the non-accumulation of the procedures, CAJASALAMANCA is unable to present a single defect or procedural infringement that has effectively limited its right to defense, when the allegations presented by the affected Rural Banks regarding the security incident are substantially similar, and they have had access to all the documentation that affects them in a common manner. In any case, the instructing body will incorporate into the procedure and inform CAJASALAMANCA of any other documents that may constitute evidence relevant to the facts.

4.2.- The intimate connection as a requirement for the individualization of responsibility for the same facts.

C/ Jorge Juan, 6

www.aepd.es

CAJASALAMANCA argues that, since we are dealing with a single breach of personal data, the processing of separate procedures for each of the responsible entities may eventually lead to the determination of different responsibilities. The intimate connection translates into the principle of uniqueness in determining the concurrence of facts when, as CAJASALAMANCA claims, there are unique facts that result in a single breach of personal data.

As previously motivated, it cannot be said that there is a single breach of personal data, but rather as many as there are data controllers who have suffered the security incident regarding their clients' data. There cannot be different degrees of responsibility between CAJASALAMANCA and the other entities. Each of the data controllers will have a degree of responsibility that must be determined individually regarding compliance with data protection regulations, without any type of cooperation in the commission of the infringement among the different Rural Savings Banks that could determine different degrees of responsibility among the entities, as CAJASALAMANCA claims.

CAJASALAMANCA continues its reasoning by stating that "responsibility cannot be individualized without first objectifying the sanctioning reproach and this cannot be projected in 26 procedures with their own dynamics, their own evidence...". Abstract arguments are still being made, such as objectifying the sanctioning reproach, regarding its own dynamics and "its own evidence", when not even allegations have been made questioning the evidence of the facts, nor has a request for the reception of evidence in the procedure been made.

The fact that "a single investigation procedure" has been processed and that no requirement has been directed against the data controllers but rather in relation to the processor (RSI) does not imply the "unitary factual determination," as CAJASALAMANCA argues. That the inspection actions were directed to require information from the data processor does not determine that subsequently a single procedure must be initiated to clarify administrative responsibilities. It should be noted that Article 53, "Scope of the investigation activity," of the LOPDGDD does not impose that these must necessarily be carried out in relation to the data controller. Therefore, there is no obligation to investigate all the controllers that carry out the processing in question. Inspectors can obtain evidence by consulting and requiring information from the data processor if they deem it appropriate.

4.3 Impact on the fundamental right to good administration

According to CAJASALAMANCA, accumulation becomes an obligation in case the absence of it could harm the rights of the administered, particularly those recognized in Article 24 of the Constitution, thus violating the right to good administration in accordance with Article 41 of the Charter of Fundamental Rights of the European Union.

In the previous allegations, the differences between the behaviors attributed to the Cajas Rurales have been motivated, and it has been established that no type of defenselessness has been caused to CAJASALAMANCA in the processing of the present procedure, having had access to all the documents in the file. In fact, CAJASALAMANCA has not justified any type of defenselessness, nor does it point out any specific fact by which it has been caused defenselessness.

Finally, it is reiterated that we are not dealing with the same facts, but rather with the same technical problem that caused a security incident in the information system of each of the responsible entities concerning their processing of personal data (all of them legally and economically independent from each other), which has produced a series of personal data security breaches, not a single personal data security breach, but a personal data security breach in each of the Cajas Rurales, which result in the alleged commission of a series of infringements by each of the different data controllers concerning their processing of personal data and the rights and freedoms of their clients.

SECOND. THE NON-EXISTENCE OF GUILT IN THE PRESENT CASE

CAJASALAMANCA has invoked various arguments to justify the absence of guilt in its conduct. Firstly, it states that it is outside the facts attributed to it, since in the present case, the processing is carried out through a data processor; which, in turn, is the processor of the entities against which the proceedings are directed; and that the personal data protection regulations not only impose obligations related to compliance with the principle of confidentiality and the adoption of necessary security measures on the data controller but, when the processing is carried out on behalf of the controller by a data processor, also on the latter.

In this regard, it is worth recalling that the figure of the data processor responds to the need to address phenomena such as the outsourcing of services by companies and other entities, so that in those cases where the data controller entrusts a third party with the provision of a service that requires the processor to process personal data on its behalf, the processing or operations of the processing are carried out by the processor, in the name and on behalf of the controller, as if it were the latter who is carrying it out.

Therefore, the existence of a data processor depends on a decision made by the data controller, who may decide to carry out certain processing operations themselves or to contract all or part of the processing with a processor.

That is to say, the processor, in order to be one, does not hold any self-interest regarding the result of the processing subject to the assignment, without prejudice to the economic compensation it receives for the service rendered, which is what occurs in the present case. The processors have no self-interest; they act on behalf of the controller.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

34/58

account and on behalf of the data controller, fulfilling their orders and for their purposes, and this is what determines that they are appointed from the outset.

This determines that the data controller is liable for actions contrary to the GDPR carried out by their data processors, unless the latter have acted as true data controllers, deciding on the purposes and means of processing, a situation that has not occurred in the present case.

Thus, the CJEU ruling of December 5, 2023, issued in case C-683/21, regarding the question of whether an administrative fine can be imposed under Article 83 of the GDPR on a data controller in relation to processing operations carried out by a processor, determines that,

“83 Regarding, secondly, the question of whether an administrative fine can be imposed under Article 83 of the GDPR on a data controller in relation to processing operations carried out by a processor, it should be recalled that, according to the definition in Article 4, point 8, of the GDPR, a processor is understood to be ‘the natural or legal person, public authority, service, or other body that processes personal data on behalf of the data controller.’

84 Since, as indicated in paragraph 36 of this judgment, a data controller is responsible not only for all personal data processing that they carry out themselves but also for processing carried out on their behalf, an administrative fine can be imposed on that controller under Article 83 of the GDPR in a situation where personal data is subject to unlawful processing and where it is not the controller, but a processor they have engaged, who has carried out the processing on their behalf.

85 However, the liability of the data controller for the behavior of a processor cannot extend to situations where the processor has processed personal data for purposes that are their own or where they have processed such data in a manner incompatible with the framework or modalities of processing as determined by the data controller or in a manner that cannot reasonably be considered to have been consented to by that controller. Indeed, in accordance with Article 28, paragraph 10, of the GDPR, in that case, the processor must be considered a data controller with respect to that processing.”

To the above, we must add the recent SAN of February 8, 2024, rec. 0002250/2021, regarding TELEFÓNICA MÓVILES ESPAÑA S.A.U, in which it is determined that,

“Well, the appellant company is the data controller, as it determines the purposes and means of the

processing carried out for the purposes indicated in its Privacy Policy: 'At Movistar, we process customer or user data for the provision of the service, as well as for other purposes that the customer allows or authorizes in the terms informed in this Privacy Policy or in the specific Conditions of each contracted Movistar Product or Service.'

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
35/58

Whereas the companies ATENTO TELESERVICIOS ESPAÑA, S.A.U., CATHPONE-NET, S.L., and THADER TELECOMUNICACIONES S.L. are considered data processors.

The above is derived from the contracts signed by the plaintiff with the aforementioned companies.

...

Well, it has not been demonstrated that the aforementioned companies, as data processors for the plaintiff, have determined the purposes and means of the processing, nor have they used the clients' data for their own purposes, nor have they interacted with third parties outside the structure and commercial name of the appealing company, but rather they have acted under the name of the plaintiff to fulfill its purposes, using its systems to carry out operations with the clients.

Therefore, it is not possible to invoke Article 28.10 of the GDPR for a presumed attribution of responsibility to the processors that would also imply the exoneration of the data controller, that is, of the company here appealing. On the other hand, according to the aforementioned contracts, there is a clause that transfers to them any possible sanctions that the plaintiff company may suffer for non-compliance with data protection obligations.

On the other hand, the Guidelines 7/2020 of the EDPB on the concepts of "data controller" and "data processor" in the GDPR, version 2.0 adopted on July 7, 2021, determine that,

"30 Following the line of the fact-based approach, the word 'determine' means that the entity that truly exercises a decisive influence over the purposes and means of the processing is the controller.

Generally, the processing contract establishes who is the determining party (the data controller) and who is the party that follows the instructions (the data processor). Even when the data processor offers a service that is defined in advance in a specific way, it must present the data controller with a detailed description of the service, and the data controller must make the final decision on the approval of how the processing will be carried out and request any changes it deems necessary. Furthermore, the data processor cannot modify, at a later time, the essential elements of the processing without the approval of the controller.

...

39. The question is where to draw the line between the decisions reserved for the data controller and those that can be left to the discretion of the processor. It is evident that decisions regarding the purpose of the processing must always correspond to the controller.

40. As for the determination of the means, a distinction must be made between essential and non-essential means. Essential means are traditionally and inherently reserved for the data controller. These must be mandatorily determined by the data controller, although the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
36/58

The determination of non-essential means may also be left to him.

Essential means are those closely linked to the purpose and scope of the processing, such as the type of personal data processed ("What data will be processed?"), the duration of the processing ("How long will the data be processed?"), the categories of recipients ("Who will have access to the data?"), and the categories of data subjects ("To whom do the processed personal data belong?"). In addition to being related to the purpose of the processing, essential means are closely tied to the question of whether the processing is lawful, necessary, and proportionate. Non-essential means are related to

more practical aspects of the processing itself, such as the choice of a particular type of hardware or software or the decision regarding the specifics of security measures, which may be left to the data processor.

41. Although decisions regarding non-essential means may be left to the data processor, the controller must still stipulate certain elements in the contract with the processor: for example, regarding the security requirement, it may be ordered to adopt all measures required under Article 32 of the GDPR. The contract must also establish that the processor will assist the controller in ensuring compliance with, for example, the provisions of Article 32. In any case, the data controller remains responsible for implementing appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is compliant with the Regulation (Article 24). To this end, the controller must take into account the nature, scope, context, and purposes of the processing, as well as the risks to the rights and freedoms of natural persons. For this reason, the data controller must have complete information about the means used, as this will allow them to make an informed decision in this regard. In order for the controller to demonstrate the legality of the processing, it is advisable to document, in the contract or another legally binding instrument between the controller and the processor, at least the necessary technical and organizational measures.

...

74. The GDPR establishes specific obligations that directly bind data processors, as specified in section 1 of subsection II of these guidelines. It is possible to hold a processor accountable or sanction them when they fail to comply with such obligations or act outside or against the legal instructions of the controller.

...

80. Secondly, the processing must be carried out on behalf of a data controller, but not under their direct authority or control. Acting "on behalf of" someone means serving the interests of another and refers to the legal concept of "delegation." In the case of data protection regulations, the role of the data processor is to apply the instructions given by the data controller, at least concerning the purposes of the processing and the essential elements of the means. The legitimacy of the processing under Article 6 and, if applicable, Article 9 of the Regulation derives from the activity of the controller, and the processor must only process the data following the instructions given by the controller. Nevertheless, as previously indicated, the instructions of the controller...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

37/58

The processing may leave a certain margin of discretion regarding how to best serve its interests, allowing the processor to choose the most appropriate technical and organizational means.

81. Acting "on behalf of" someone also means that the processor cannot carry out the processing for its own purposes. As stipulated in Article 28, paragraph 10, the processor will violate the GDPR when it does not adhere to the instructions of the controller and begins to determine its own purposes and means of processing. In these cases, the processor will be considered responsible for such processing and may be sanctioned for not having adhered to the instructions of the controller." (emphasis added) Well, in the specific case being examined, and in light of the documentation in the file, it is noted that, for the provision of IT services, RSI and CAJASALAMANCA have entered into an individualized and specific "Service Provision Contract" with each of the entities with RSI.

Additionally, it has also entered into the framework of the previous agreement the "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between CAJASALAMANCA and RSI," an agreement related to CAJASALAMANCA, which was signed on 25/05/2018, A.A.A., on behalf of CAJASALAMANCA (controller).

In this regard, in this "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between CAJASALAMANCA and RSI," CAJASALAMANCA is identified as the controller of the processing, and in this Data Protection clause, RSI is identified as the processor. The "Processor" and the Entities are identified as the "Controllers."

Furthermore, in this "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between CAJASALAMANCA and RSI," this clause defines the processing that could be carried out by RSI on behalf of CAJASALAMANCA, the type of information to be processed, and the categories of data subjects whose data could be processed.

It is also defined that the security measures that must be applied by RSI to ensure an adequate level of security in accordance with the provisions of Article 32 of the GDPR are those established in Annex B of the "Agreement to Modify the Data Protection Clause of the Service Provision Contracts between CAJASALAMANCA and RSI."

We must also highlight that it is stated in section 6 of the Agreement regarding "Liability" that, "If the Processor, or if applicable, the contractors, violate this Agreement or the current regulations by determining the purposes and means of processing, they will be considered responsible for the processing concerning such processing."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

38/58

In the event that a supervisory authority sanctions the Data Controller as a direct consequence of the Data Processor's failure to comply with the stipulations of this Agreement, the Data Processor shall indemnify the Data Controller as stipulated in the liability clause of the current framework contract between the parties.

This implies, by contrast, and in accordance with data protection regulations, the aforementioned rulings, and Guidelines 7/2020, that the Data Controller is responsible for the actions carried out by its Data Processor unless the latter determines the purposes and means, resulting in the fact that this last issue has not been proven in the processed procedure.

Therefore, in accordance with the above, CAJASALAMANCA and RSI are the Data Controllers responsible for the processing being carried out; they are the ones who have decided to entrust a Data Processor to carry it out on their behalf and for their account. They are the entity that has the true capacity to exercise control over the processing of personal data, determining which personal data will be processed on their behalf and for their account, the why and how these data should be processed, as they define the purpose of the personal data processing that their activity entails and choose the means they consider appropriate.

And according to all the above, in the specific case, CAJA XXX is responsible for the infringement of the GDPR even if it has occurred within its Data Processor. This is regardless of the actions and responsibilities that third parties may have incurred, as the negligence or illegal actions of third parties do not exclude their own.

In this regard, in the very Agreement of Initiation, it is indicated in section 4 concerning the Obligations of the Data Controller that:

"It is the responsibility of the Data Controller:

- a) To provide the Data Processor with the necessary data for the provision of the service.
- b) If legally required, to carry out a data protection impact assessment of the processing operations to be carried out by the Data Processor.
- c) To carry out the necessary prior consultations.
- d) To ensure, beforehand and throughout the processing, compliance with the GDPR by the Data Processor.
- e) To supervise the processing, including conducting inspections and audits."

This is directly related to the principle of proactive responsibility of the Data Controller provided for in Article 5.2 of the GDPR, which establishes that "the Data Controller shall be responsible for compliance with the provisions of paragraph 1 and capable of demonstrating it ("proactive responsibility"). This means that the Data Controller must ensure the effective application of the principles of processing both at the time of determining the means of processing and during the processing itself, whether it carries out the processing of personal data directly or not.

C/ Jorge Juan, 6

entrust a data processor to carry it out on their own (for the purposes of data protection regulation, it is the same), through the implementation of a series of technical and organizational measures of all kinds, which must be subject to periodic review and updating. This implies that the aforementioned controller is the one who assumes their own responsibility by directing, reviewing, and coordinating the processing, including that of the personnel and the data processor providing services to them.

The Opinion 3/2010, from the Article 29 Working Party (WP29) -WP 173- issued during the validity of the repealed Directive 95/46/EC, but whose provisions are applicable today, states that the “essence” of proactive responsibility is the obligation of the data controller to apply measures that, under normal circumstances, ensure that the data protection rules are complied with in the context of processing operations and to have available documents that demonstrate to the data subjects and the supervisory authorities what measures have been adopted to achieve compliance with data protection rules.

For these purposes, consideration is given to what is stated in the following Recital 74 of the GDPR: “74.

The responsibility of the data controller for any processing of personal data carried out by them or on their behalf must be established. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.”

Completing the above and in development of Article 5.2 of the GDPR, Articles 24 and 25 of the same legal text must be cited, the latter regarding “Data protection by design and by default” stating that the fundamental right to the protection of personal data is much more than mere technology, as its approach is on the risks to the rights and freedoms of data subjects arising from the processing of personal data,

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed...”

C/ Jorge Juan, 6

CAJASALAMANCA seems to argue that the responsibility lies with the data processor with whom it signed a contract, and under which it was obliged to implement appropriate security measures according to the risk. However, it is worth noting that the personal data breach occurred as a result of CAJASALAMANCA's decision to switch from the Ruralvía Clásica application to a new NBE application for its clients to access electronic banking, subscribing for this purpose to the corresponding data processing agreement with RSI, where CAJASALAMANCA established the appropriate conditions.

Moreover, this is in addition to what has been stated by this Agency in previous paragraphs regarding CAJASALAMANCA having determined the purposes and means of the processing, being responsible

for the processing, being liable for the personal data breach in this case due to the processing actions carried out by its data processor on its behalf, and being subject to the obligations of the GDPR, especially concerning proactive responsibility.

This is CAJASALAMANCA's responsibility because it is the data controller and is obligated to integrate and deploy data protection within all that constitutes its organization, in all its areas of action, whether affecting its employees or its data processors. It must be kept in mind that ultimately the determining purpose is to guarantee the protection of the data subject, as the focus is on the risks to the rights and freedoms of the data subjects arising from the processing of personal data.

Therefore, the data controller must carry out a risk analysis regarding the rights and freedoms of natural persons in data processing, implementing appropriate technical and organizational measures to apply the principles of data protection and integrate the necessary safeguards in the processing, in order to comply with the requirements of the GDPR, being able to demonstrate that the processing is in accordance with the provisions of the aforementioned regulation. In light of the principle of proactive responsibility (art. 5.2 GDPR), the data controller must be able to demonstrate that it has taken into account all the elements provided for in the GDPR.

Thus, all of this merely reflects a lack of diligence on the part of the investigated entity in ensuring adequate security relative to the risks of the data processing it carries out. In this regard, it should not be forgotten that the affected database contains personal data of thousands of clients, which constitutes large-scale processing, and which, in turn, is accessed from web applications, that is, from the internet, with a very significant exposure surface, posing greater risks for the data subjects, which requires appropriate technical and organizational measures of all kinds, including security measures, suitable for this purpose and specifically aimed at ensuring that there is no unlawful access to such personal data.

As has been demonstrated and argued throughout this sanctioning procedure, it is considered that appropriate security measures were not implemented in this case to ensure adequate security relative to the risk, even if there had not been a personal data breach, the security of the personal data of the clients, which determined in this case an access.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/58

illegitimate access to the personal data of CAJASALAMANCA's clients. Therefore, no liability is being demanded as a consequence solely of a result caused by a cyberattack. It is something else entirely that has been revealed in the context of a violation of the security of personal data. It is much more; it is a failure to comply with the obligations imposed by the GDPR. Therefore, it is emphasized that the data controller must establish clear modalities for such assistance in its relationship with the data processor and provide precise instructions to the data processor on how to comply with them adequately and document it beforehand through a contract or in another (binding) agreement, and also subsequently during the validity of the same, and verify at all times during the execution of the contract its compliance in the manner established therein.

It suffices to bring to mind the content of the Supreme Court ruling STS 1562/2020, which states the following:

“In this regard, the Supreme Court ruling of June 5, 2004, which confirms, in cassation for the Unification of Doctrine, that of this AN of October 16, 2003, echoing the arguments made by this Chamber, refers to the differentiation of two controllers based on whether the decision-making power is directed at the file or at the data processing itself. Thus, the file controller is the one who decides the creation of the file and its application, as well as its purpose, content, and use, that is, who has decision-making capacity over all the data recorded in that file. The data processor, however, is the subject to whom decisions regarding the specific activities of a particular data processing are attributable, that is, regarding a specific application. This would involve all those cases in which the decision-making power must be differentiated from the material execution of the activity that comprises the processing. With this, as also argued by the STS of April 26, 2005 (cassation for unification of

doctrine 217/2004), the Spanish legislator aims to adapt to the requirements of Directive 95/46/EC, which seeks to provide a legal response to the phenomenon, increasingly frequent, of the so-called outsourcing of IT services, where multiple operators act, many of them insolvent, created with the aim of seeking impunity or irresponsibility for those who follow them in the subsequent links of the chain. Currently, the new Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data (which repeals Directive 95/46/EC, and is directly applicable from May 25, 2018) also distinguishes between the figures of the controller and the processor. The former is defined in paragraph 7) of Article 4 as "a natural or legal person (...) who determines the purposes and means of the processing." And the processor in paragraph 8) of the same Article 4 as one who "processes personal data on behalf of the controller."

This is in relation to Articles 24 and 28 of the same European Data Protection Regulation. Controller and processor of personal data who, without a doubt, are also responsible for infringements in the field of data protection, in this new regulatory framework, in accordance with the provisions of Article 82.2 of the aforementioned Regulation (EU) 2016/679, which states: Any controller who

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
42/58

Those participating in the processing operation shall be liable for damages caused in the event that such operation does not comply with the provisions of this Regulation. A processor shall only be liable for damages caused by the processing when it has not complied with the obligations of this Regulation specifically directed at processors or has acted outside or against the legal instructions of the controller. It follows from all the above that the involvement, in this case, of a processor of ZZZZ does not exempt the entity XXXX, now the appellant, from liability, despite the strength of the clauses contained in the contract and its annex signed by both companies (proven facts 9 and 10) regarding the personal data processed for the purpose of carrying out an advertising campaign concerning car and motorcycle insurance marketed by XXXX, ultimately benefiting said XXXX, being the acting entity that ultimately determines the purposes and means of the repeated data processing, and therefore cannot be exempted from liability"...

The Supreme Court continues, in relation to the possible exemption of liability alleged concerning what was signed in the "processor" contract, as follows:

"The sanctioned conduct of obstruction or impediment by XXXX of its client's exercise of the right to object to the processing of their data is manifested in that said company did not adopt any measures or precautions to prevent the sending of advertising to its client's email addresses by those companies to which it entrusted the execution of the advertising campaigns.

The adoption of the necessary measures or precautions to ensure the effectiveness of the right to object to the processing of their data by XXXX, as the data controller, remains in place even if the advertising campaigns are not carried out based on data from its own files, but rather with databases from other companies contracted by XXXX, and in this case, it was established that the appellant did not communicate to the companies with which it contracted the provision of advertising services the complainant's objection to receiving advertising from the Mutual, nor did it ultimately adopt any provision to ensure the exclusion of its client from the advertising mailings contracted with third parties."

Regarding the application of the principle of culpability in the field of sanctioning law regulated by the GDPR, the investigated entity brings up the doctrine established by the CJEU ruling of December 5, 2023 (case C-807/21, Deutsche Wohnen SE and Staatsanwaltschaft Berlin).

Well then, it is worth asking what the parameters of due diligence that the investigated entity should have observed in relation to the examined conduct are. The answer is that the diligence it should have observed is the one necessary to fulfill the obligations imposed on it by Articles 5.2, 24, and 25 of the GDPR, in light of the doctrine of the National Court and the jurisprudence of the Supreme Court.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
43/58

The SAN of October 17, 2007 (rec. 63/2006) is fully applicable to this case, which, after referring to the fact that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, states:

(...) the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not behave with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, there must be an insistence on rigor and exquisite care to comply with the legal provisions in this regard.”

Furthermore, the National Court in matters of personal data protection has declared that “simple negligence or failure to comply with the duties imposed by law on those responsible for files or data processing to exercise extreme diligence is sufficient...” (Judgment of the National Court of June 29, 2001).

Regarding the allegation made that the breach of personal data occurred within the framework of the data processing for which RSI was responsible, to the extent of carrying out the investigative actions exclusively with that entity, it should be noted that the preliminary investigative actions are precisely carried out to clarify the facts and circumstances of what happened, gathering more information in order to determine whether or not there is a possible infringement of the data protection regulations. In this sense, the initiation of preliminary investigations and their execution, which is the authority of the AEPD, does not prejudice anything but allows for the determination of the facts that occurred and the gathering of necessary information wherever it may be found to determine if there are indications of infringement or not. Even after such an investigation, it may be that the proceedings are archived because, based on the information gathered, it is understood that there are no indications of infringement. This has not happened in the present case.

Consequently, the allegations must be dismissed since the investigated entity has infringed the obligations imposed by the GDPR as the data controller for the processing carried out in its name and on its behalf, in relation to the responsibilities required of every data controller by Article 24 of the GDPR. Therefore, the allegations must be dismissed, noting that the arguments presented do not undermine the essential content of the infringement declared nor do they constitute sufficient justification or exculpation.

THIRD. ON THE IMPACT ON THE PRINCIPLES OF SANCTIONING LAW DERIVED FROM THE INTERPRETATION MADE BY THE AEPD

CAJASALAMANCA considers that it has not committed any infringement of the Data Protection regulations, much less the simultaneous infringement of Articles 5.1 f) and 32 of the GDPR, as the triple identity of subject, fact, and protected legal interest coincides; there is no doubt that in this case the principle of non...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
44/58

bis in ídem, with the imposition of the sanction only under article 5.1.f) as it is more serious than either of the two alleged infringements.

And in the event that the AEPD recognizes the violation, it should subsidiarily recognize a medial concurrence as one of the infringements is subsumed and embedded in the other, as provided in article 29.5 of the LRJSP, “When the commission of one infringement necessarily results in the commission of another or others, only the sanction corresponding to the most serious infringement committed shall be imposed.”

“1. Violation of the non bis in ídem principle in the application of articles 5.1 f) and 32 of the GDPR”

In this regard, and concerning this allegation made by CAJA XXX against the initiation agreement, it should be noted that since the filing of the initially alleged infringement under article 32 of the GDPR has been proposed, it is no longer necessary to respond to these allegations, as the accusation under article 5.1.f) of the GDPR no longer coincides with article 32 of the GDPR.

FOURTH. ON THE ALLEGED VIOLATION OF ARTICLE 32.1 OF THE GDPR.

CAJASALAMANCA has stated that the AEPD considers the alleged violation of article 32 of the GDPR to be “evidenced,” that is, it considers the supposed insufficiency of the security measures adopted to be evident due to the occurrence of the personal data breach, making exclusive reference to the report on the breach contained in the administrative file, neglecting in the initiation agreement all the measures adopted as well as the audit carried out, and that there is a misinterpretation of what occurred in the RSI systems, (...).

Well, as indicated, upon reviewing the allegations made by the accused party, and in consideration of them, reviewing the documentation in the administrative file and that provided by the accused party, it is evident that all the technical and organizational security measures whose absence has been proven have had a direct impact on the personal data breach, without there being a violation, in this specific case, of article 32 of the GDPR as the absence of other independent technical and organizational security measures from the personal data breach has not been demonstrated.

Regarding the sufficiency of the security measures, in relation to the non-compliance with article 5.1.f) of the GDPR, we refer to what has already been indicated in the legal basis IV of this resolution proposal, where it is explained and justified in detail why they were neither sufficient nor appropriate. Furthermore, we will indicate that it is true that it is recorded that, both prior to and subsequent to the security incident, the investigated entity conducted audits and reviews by third-party specialists aimed at detecting vulnerabilities related to the security of the information systems; but it is also true that despite the existence of such investigations, controls and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

45/58

The checks were unable to locate and reveal the existing vulnerabilities, as stated in the proven facts. CAJASALAMANCA claims that RSI holds various certifications in the field of security, referenced in the third proven fact of this resolution proposal.

Article 28 of the GDPR, Processor, in its paragraph 5, establishes that:

“5. The adherence of the processor to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may be used as an element to demonstrate the existence of sufficient guarantees referred to in paragraphs 1 and 4 of this article.”

In this regard, to demonstrate that processors offer the suitability and guarantees required by the GDPR, adherence to a certification mechanism can be used as an additional element to establish the existence of sufficient guarantees to implement appropriate technical and organizational measures to protect personal data.

This is because, in addition to a processor being certified in data protection, this certification does not absolutely prove that sufficient guarantees in relation, in this case, to the provision of Article 28.1 of the GDPR, have been implemented and are effectively operating throughout the entire processing cycle and during the time in which the processing is taking place.

In the field of data protection, these types of instruments are voluntary compliance mechanisms that establish specific rules with the aim of contributing to the correct application of the GDPR and the LOPDPGDD.

According to the GDPR, the data controller must adopt appropriate measures, including the selection of processors, in such a way as to ensure and be able to demonstrate that the processing is carried out in accordance with the GDPR (principle of active accountability).

It is true that the certifications that the processor RSI appears to hold are mentioned in the data processing agreement; however, let us note that all the certifications listed in the third proven fact are not certifications as provided for in either Article 28 or Article 42 of the GDPR, nor are they data

protection certifications, but rather certifications of information security or related to other obligations that must be fulfilled by the controller or the processor based on different regulations from those of data protection.

Thus, in the “Amendment Agreement of the Data Protection Clause of the Service Provision Contracts,” signed between CAJASALAMANCA and RSI, in its “Annex B - Security Measures to the Amendment Agreement of the Data Protection Clause of the Service Provision Contracts,” it is indicated that RSI holds the following certifications:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
46/58

(...)

Furthermore, the reference in the engagement contract is not accompanied by the certification itself for the purpose of verifying that it has indeed been certified and to see exactly what it is certified for, at what moment it was certified, and whether the certification was still valid at the time of the personal data breach (given that certifications have a validity period); this certification does not pertain to data protection.

In this regard, the report of the Legal Cabinet 170/2018 of the AEPD establishes the difference between information security and the protection of personal data. Thus, it is indicated that, “Prior to analyzing the specific issue raised in the consultation, this Legal Cabinet finds it appropriate to make a prior reference to the substantive and jurisdictional differentiation that exists between the field of information security and that of the protection of personal data.

Regarding information security, it encompasses the set of techniques and measures aimed at ensuring the confidentiality, integrity, and availability of information and data important to any organization, regardless of their format. (...)

On the contrary, the protection of personal data of natural persons is configured as a true fundamental right that finds its basis in Article 18.4 of the Spanish Constitution, according to which “the law will limit the use of computing to guarantee the honor and personal and family privacy of citizens and the full exercise of their rights.” This has been recognized by our Constitutional Court, highlighting in Judgment 94/1998, of May 4, that the aforementioned Article 18.4 “not only entails a specific instrument for the protection of citizens’ rights against the tortious use of computing technology, but also enshrines an autonomous fundamental right to control the flow of information concerning each person - to ‘privacy’ according to the neologism stated in the Explanatory Memorandum of the LORTAD - whether or not it belongs to the strictest realm of intimacy, in order to preserve the full exercise of their rights.”

This is reflected in the Preamble of the Organic Law Project on Personal Data Protection and Guarantee of Digital Rights, which for its clarity is transcribed below:

“The protection of natural persons in relation to the processing of personal data is a fundamental right protected by Article 18.4 of the Spanish Constitution. In this way, our Constitution was a pioneer in recognizing the fundamental right to the protection of personal data when it provided that ‘the law will limit the use of computing to guarantee the honor and personal and family privacy of citizens and the full exercise of their rights.’ It echoed the work developed since the late 1960s in the Council of Europe and the few legal provisions adopted in countries in our environment.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
47/58

The Constitutional Court stated in its Judgment 94/1998, of May 4, that we are faced with a fundamental right to data protection, which guarantees individuals control over their data, any personal data, and over its use and destination, to prevent the illicit trafficking of such data or harm to the dignity and rights of the affected parties; thus, the right to data protection is configured as a citizen’s power to

oppose the use of certain personal data for purposes other than those that justified its acquisition. For its part, in Judgment 292/2000, of November 30, it considers this right as an autonomous and independent right that consists of a power of disposition and control over personal data, enabling individuals to decide which of those data to provide to a third party, whether the State or a private individual, or which data this third party may collect, and that also allows individuals to know who holds that personal data and for what purpose, being able to oppose such possession or use.

At the legislative level, the specification and development of the fundamental right of protection of individuals in relation to the processing of personal data took place initially through the approval of Organic Law 5/1992, of October 29, regulating the automated processing of personal data, known as LORTAD. Organic Law 5/1992 was replaced by Organic Law 15/1999, of December 5, on the protection of personal data, in order to transpose into our law Directive 95/46/EC of the European Parliament and of the Council, of October 24, 1995, regarding the protection of individuals in relation to the processing of personal data and the free movement of such data. This organic law represented a second milestone in the evolution of the regulation of the fundamental right to data protection in Spain and was complemented by an increasingly abundant jurisprudence from the contentious-administrative jurisdictional bodies.

On the other hand, it is also included in Article 8 of the Charter of Fundamental Rights of the European Union and in Article 16.1 of the Treaty on the Functioning of the European Union. Previously, at the European level, the aforementioned Directive 95/46/EC had been adopted, whose purpose was to ensure that the guarantee of the right to the protection of personal data did not constitute an obstacle to the free movement of data within the Union, thus establishing a common space for the guarantee of the right that simultaneously ensured that in the event of international data transfer, its processing in the destination country was protected by safeguards adequate to those provided for in the directive itself.

And in this same sense, the Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, regarding the protection of individuals in relation to the processing of their personal data and the free movement of such data, which repeals Directive 95/46/EC (General Data Protection Regulation, GDPR), states that its objective is “to protect the fundamental rights and freedoms of natural persons and, in particular, their right to the protection of personal data” (Article 1.2.), highlighting in its Recital 1 that “the protection of natural persons in relation to the processing of personal data is a fundamental right” and in its Recital 10 that “to ensure a consistent and high level of protection of natural persons and to eliminate obstacles to the free movement of personal data within the Union, the level of protection of the rights and freedoms of natural persons with regard to the processing of personal data should be equivalent throughout the Union.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

48/58

refers to the treatment of such data must be equivalent in all member states. It must be ensured throughout the Union that the application of the rules for the protection of the rights and fundamental freedoms of natural persons in relation to the processing of personal data is consistent and homogeneous.”

Consequently, the right to the protection of personal data of natural persons is a fundamental right and, therefore, situated at the highest level of legal protection, which is currently directly regulated by community legislation, with the aforementioned GDPR establishing a set of principles, rights, obligations, and an organizational structure aimed at guaranteeing this fundamental right. Among these, information security appears as an additional obligation for the controllers and processors of data, who must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which will include, among other factors, “the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services” and “the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident” (Article 32.2. b) and c) of the GDPR).

Therefore, there is no doubt that the guarantee of the security of personal data acquires special significance regarding its protection, but without being limited exclusively to the area of security of that information, as the protection of personal data has a much broader scope that encompasses, as we said, a set of principles, rights, and obligations that is much wider.”

This issue is substantial since the certification mentioned in the service contract does not serve as an element to “demonstrate the existence of sufficient guarantees referred to in paragraphs 1 and 4” of Article 28 of the GDPR, as it does not concern data protection. The difference in approach between mere information security and data protection is extremely important, as while the former focuses exclusively on the security of information, the risk-based approach of the GDPR (which is much broader as it focuses on the risks to the rights and freedoms of data subjects arising from the processing of personal data) focuses on natural persons, with security being just one obligation among those of the GDPR to achieve the protection of natural persons in the terms of the recitals, particularly 1 and 10, as well as in accordance with the provisions of Article 1 of the GDPR.

Within the management of GDPR compliance lies risk management, on which information security pivots and not the other way around.

(...)

CAJASALAMANCA claims that the security measures initially implemented by RSI are outlined in the service contract signed with RSI and that the attackers may have legitimate credentials for access and that the attack is not due to the weakness of the systems implemented.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

49/58

As a preliminary matter, we must refer to the proven facts and the description of the personal data breach to understand how and why the personal data breach occurred.

Regarding the security measures outlined in the "Amendment Agreement to the Data Protection Clause of Service Provision Contracts," the reference to security measures refers to those specified in Annex B - Security Measures to the Amendment Agreement to the Data Protection Clause of Service Provision Contracts.

Well, from a detailed examination of the citation of the same, since we are unaware of the description of the specific measures implemented, we can again verify that they are measures that refer generally to information security and not to data protection (...). A policy is a central and guiding instrument of an organization in which the responsible party addresses its objectives and establishes procedures, resources, and mechanisms to carry it out, which requires subsequent detailed development. It is not the same to address mere information security as it is to address the protection of a fundamental right such as data protection, considering the focus and purpose of each.

Furthermore, the fact that a list of measures appears in a service contract (also in this specific case, information security measures) does not imply that they guarantee appropriate security as determined by Article 5.1.f) of the GDPR, because it will be necessary to focus on the protection of the rights and freedoms of the data subjects, and the measures implemented do not necessarily serve to fulfill that objective if they have not been designed and implemented from the perspective required by the GDPR.

FIFTH. ON THE ALLEGED VIOLATION OF ARTICLE 5.1.f) OF THE GDPR.

CAJASALAMANCA considers the contradiction in which the Initiation Agreement incurs by stating that "the identification of a personal data breach does not imply the direct imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the controllers and processors and the security measures applied," when it subsequently understands that Article 5.1.f) has been violated as a consequence of the mere fact that the breach has occurred.

On this particular matter, we refer to the legal basis IV explaining the concurrence of the violation of Article 5.1.f) of the GDPR in this specific case, where it is detailed that the violation has not been committed merely due to the result of loss of confidentiality, even though it is a result-based violation. The Judgment of the Constitutional Court (STC) 292/2000, in its analysis of the "content" of the

fundamental right to data protection, refers to the power of disposition and control that belongs to the data subject over the possible use or uses of their data by a third party. Legal Basis seventh states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/58

“[...] it turns out that the content of the fundamental right to data protection consists of a power of disposition and control over personal data that enables the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which data this third party may collect, and that also allows the individual to know who holds that personal data and for what purpose, being able to oppose such possession or use. These powers of disposition and control over personal data, which are part of the content of the fundamental right to data protection, are legally concretized in the authority to consent to the collection, obtaining, and access to personal data, its subsequent storage, as well as its possible use or uses by a third party, whether the State or a private individual.” The obligation of confidentiality imposed on the data controller by Article 5.1(f) of the GDPR is an obligation of result, such that for the provision to be considered violated, the confidentiality of the data must be breached.

As specified by the Supreme Court ruling of 15/02/2022 (rec. of cassation 7359/2020):

“The obligation to adopt the necessary measures to ensure the security of personal data cannot be considered an obligation of result, which implies that once a leak of personal data to a third party occurs, there is liability regardless of the measures adopted and the activity carried out by the data controller or processor.

In obligations of result, there is a commitment to fulfill a specific objective, ensuring the achievement or proposed result, in this case, guaranteeing the security of personal data and the non-existence of leaks or security breaches (...)

It should be noted that the data controller incurs in contradiction when, on the one hand, it considers that there has been no violation of data protection regulations and believes that everything should lead to the filing of the case, while on the other hand, it confirms and indicates that it is evidenced in the file “that the attacker could access the data, but in no case alter it, ...”; (...).

And also that: “The evidence collected in the database indicates that the cybercriminal is capable of manipulating system variables to obtain information from the affected clients, and manages to connect to the new ruralvía using the identity of the affected client through a weakness in the Single Sign-On (SSO) process.”

Regarding the allegations reiterated by the responding party that the infringements attributed concerning Article 5.1(f) and 32 of the GDPR are identical since we are faced with the same fact subject to double imputation, we refer to what has already been indicated in the preceding legal grounds regarding the proposal to file the infringement of Article 32 of the GDPR.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/58

In light of the above, it is established that CAJASALAMANCA has violated the principle of confidentiality and data integrity, a principle enshrined in Article 5.1.f) of the GDPR, an infringement classified under Article 83.5.a) of the GDPR.

SIXTH. ON THE ALLEGED VIOLATION OF ARTICLE 33 OF THE GDPR

Regarding the allegations made by the claimant concerning the attribution of Article 33 of the GDPR, a response is no longer necessary, as, as stated in the proven facts and in the preceding legal grounds, the filing of the initially attributed infringement is proposed in consideration of the specific circumstances of the case previously expressed.

SEVENTH. VIOLATION OF THE PRINCIPLE OF PROPORTIONALITY IN THE DETERMINATION OF

SANCTIONS.

CAJASALAMANCA has argued that if it is considered that there has been a violation of the data protection regulations, particular consideration should be given in determining the sanction that may be imposed by applying the principle of proportionality.

It should be noted that Article 83.1 of the GDPR states that "Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive."

Therefore, the fines, as deduced from the invoked provision, must be effective, proportionate, and dissuasive to achieve the purpose intended by the GDPR.

It is true that for this system to function with all its guarantees, it is necessary for several elements to be deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to aggravating or mitigating circumstances not provided for in the GDPR - or in the LOPDGDD in the Spanish case as permitted by the GDPR itself - would undermine the effectiveness of the system, losing its meaning, its teleological purpose, and the legislator's intent, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and dissuasive. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR is equipped with its own principle of proportionality that must be applied in its strict terms. Regarding the principle of proportionality of sanctions, the National Court has stated in numerous rulings that the principle of proportionality...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/58

cannot escape judicial control, as the margin of appreciation granted to the Administration in imposing sanctions within the legally established limits must be developed by weighing, in any case, the concurrent circumstances, in order to achieve the necessary and due proportion between the alleged facts and the responsibility required, given that any sanction must be determined in accordance with the severity of the infringement committed and based on a criterion of proportionality in relation to the circumstances of the act. Thus, proportionality constitutes a normative principle that is imposed on the Administration and that reduces the scope of its sanctioning powers.

In accordance with the circumstances present in this case, which have been meticulously and appropriately evaluated, this resolution does not violate the principle of proportionality in determining the imposed sanctions, resulting in a balanced and proportionate response to the severity of the infringement committed, the importance of the facts, as well as the circumstances taken into account to grade the sanction, without any reasons being appreciated that further justify the reduction made, especially considering the amount to which such sanctions may rise in accordance with Article 83.5 of the GDPR, which provides for a maximum administrative fine of €20,000,000 or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount.

In this case, the entity under investigation is a large company within its sector of activity; according to the proven fact twenty-first, its turnover (gross margin) during the year 2022 amounted to (...) €, resulting in the fine imposed for the infringement of Article 5.1.f) of the GDPR amounting to €250,000, which would be at the lower end of the possible administrative fine that could be imposed on the data controller and far from the maximum of 4% of the total annual global turnover of the previous financial year considering the turnover.

- CAJASALAMANCA considers, regarding the circumstance derived from the nature, severity, and duration of the infringement, that the mere reference to the provision subject to the infringement is taken as an aggravating factor.

However, such an argument cannot be accepted as inconsistent; in fact, what is being highlighted is that the infringement of Article 5.1.f) affects one of the basic principles on which the regulations on the protection of personal data are based, confidentiality, and this violation is heightened and aggravated by the number of individuals affected by the incident, the damages caused (irreversible loss of power and control over personal data by clients), and its duration, since "although the breach was detected on December 7, 2022, previous accesses to that date are confirmed, with the highest volume of accesses occurring between November 10 and November 23, 2022," without having been detected.

- CAJASALAMANCA considers, regarding the intentionality or negligence in the infringement, that the lack of diligence in its actions is due to

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/58

exclusively to its status as a financial entity and, in truth, the aforementioned assertion is surprising. Considering that the conduct of CAJASALAMANCA involves the element of culpability, which is essential to impose sanctioning responsibility, in this case, it is specifically manifested in a very serious lack of diligence in complying with the principle of confidentiality of personal data, as has been demonstrated throughout the proceedings.

RSI has stated that:

(...)

Moreover, the lack of diligence demonstrated in the infringing conduct for which it is held responsible must be classified as very serious; CAJASALAMANCA is obliged under Article 5.2 of the GDPR to carry out the appropriate activities to comply with the principles of data protection, particularly, the principle of confidentiality, and to be able to demonstrate its compliance.

- CAJASALAMANCA considers that taking its banking activity into account as an aggravating factor is a sort of objective aggravating factor; in the first instance, it is not a matter related to the specific activity carried out by a particular entity, but rather the aggravating factor provided for in Article 76.2.b) of the LOPDGDD operates when the infractor's activity is linked to the processing of personal data, and it is obvious that, in relation to the present data controller, its activity, in this specific banking case, is clearly linked, directly, to multiple processing of personal data affecting thousands of clients.

In this regard, the National Court has considered it correct to appreciate the aggravating factor provided for in Article 76.2.b) of the LOPDGDD whenever the aforementioned linkage exists, and it has considered this in numerous judgments, including the one dated 04/07/2024, (rec. 382/2022) which states regarding the aforementioned circumstance that:

"As well, the aggravating factor of the continued nature of the infringement, as set out in Article 76.2.a) of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights, can also be appreciated, referring to it when we analyze the application of the GDPR to the infringement at hand. As well, the appreciation of the linkage of the infractor's activity with the processing of personal data (Article 72.2.b) of Organic Law 3/2018, of December 5), due to the fact that the activity of the appellant is linked to the processing of data from both clients and third parties; this linkage is well known since the entity, due to its activity, is in constant contact with clients and third parties handling a large volume of data, which imposes a greater duty of diligence."

(the underlining is ours).

Finally, CAJASALAMANCA considers that the AEPD, in modulating its responsibility, has not taken into account elements to mitigate it, such as evidentiary elements that demonstrate compliance with the highest standards in security matters, nor the fact that it subjected the measures adopted to a periodic audit system or that RSI resolved the vulnerability that constituted the security breach; it is sufficient to refute what has been stated by referring to the content of the proven facts and regarding the last issue raised, to refer to what the data processor itself indicates in its notification of the personal data breach, dated 14/12/2022, and the document of 10/01/2023 transmitting the final report, in which it responds to the following questions:

- Could the breach have been avoided by adopting any additional security measures?

Yes

- Did the incident occur due to any failure, deficiency, or non-compliance with implemented security measures?

Yes

And regarding the actions taken after the incident:

- Have you adapted/improved your security procedures and policies?

No

Therefore, the allegation made regarding the violation of the principle of proportionality cannot be accepted.

In light of the above, the following

PROPOSAL FOR RESOLUTION

is issued by the Director of the Spanish Agency for the Protection of Data to sanction CAJA RURAL DE SALAMANCA, S.C.C. with NIF F37015856, for the infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the GDPR, with a fine of €250,000 (two hundred fifty thousand euros).

That the Director of the Spanish Agency for the Protection of Data archives CAJA RURAL DE SALAMANCA, S.C.C. with NIF F37015856, for the infringement of Article 32.1 of the GDPR, classified under Article 83.4.a) of the GDPR.

That the Director of the Spanish Agency for the Protection of Data archives CAJA RURAL DE SALAMANCA, S.C.C. with NIF F37015856, for the infringement of Article 32.1 of the GDPR, classified under Article 83.4.a) of the GDPR.

Likewise, in accordance with the provisions of Article 85.2 of the LPACAP, it is informed that it may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be established at €200,000 (two hundred thousand euros) and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures. The effectiveness of this reduction will be conditioned to the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

55/58

withdrawal or waiver of any action or appeal in the administrative pathway against the sanction.

In the event that you choose to proceed with the voluntary payment of the amount specified above, in accordance with the provisions of the aforementioned Article 85.2, you must make it effective by depositing it into the restricted account No. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason, for voluntary payment, for the reduction of the amount of the sanction. Furthermore, you must send the proof of payment to the General Inspection Subdirectorato to proceed with closing the file.

In virtue of this, you are notified of the above, and the procedure is brought to your attention so that within TEN DAYS you may argue whatever you deem appropriate in your defense and present the documents and information you consider pertinent, in accordance with Article 89.2 of the LPACAP.

R.R.R.

INSPECTOR/INSTRUCTOR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

56/58

ANNEX

(...)

>>

SECOND: On December 21, 2024, the respondent has proceeded to pay the sanction in the amount of 200,000.00 euros, making use of the reduction provided in the resolution proposal transcribed above.

THIRD: The payment made entails the waiver of any action or appeal in the administrative pathway against the sanction, in relation to the facts referred to in the resolution proposal.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

57/58

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the impropriety of the latter has been justified, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except with respect to the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which are cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness will be conditioned upon the withdrawal or waiver of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation.

III

Voluntary Payment

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified proposal for resolution allowed for the voluntary payment of the proposed sanction, which would entail a reduction of 20% of its amount. With the application of this reduction, the sanction would be established at 200,000.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the aforementioned proposal for resolution, and before a resolution was issued by this authority, the summoned party, on December 21, 2024, proceeded to make the voluntary payment, availing itself of the 20% reduction and waiving any action or administrative appeal.

It should be noted that, in accordance with the provisions of the LPACAP, as well as the jurisprudence

of the high court in this matter, the exercise of voluntary payment by the alleged responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all matters raised by the interested parties and any others arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the proposal for resolution transcribed in this resolution.

The sum of the aforementioned amounts yields a total of 250,000.00 euros.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

58/58

After the summoned party proceeded with the prompt payment, although without acknowledgment of responsibility, it is hereby resolved, pursuant to Article 85 of the LPACAP, to reduce the total mentioned by 20%, resulting in a final amount of 200,000.00 euros.

SECOND: TO DECLARE the termination of procedure EXP202400058, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: TO NOTIFY this resolution to CAJA RURAL DE SALAMANCA, S.C.C.

FOURTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment on the withdrawal or waiver of any action or administrative appeal, this authority accepts the waiver expressly stated by the summoned party, thus precluding the filing of an optional appeal for reconsideration against this resolution, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since no administrative appeal can be filed due to the express waiver, this resolution will be fully enforceable from the notification thereof.

However, in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative route may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal.

If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension terminated.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to vacancy in the position of Presidency and Deputy Presidency

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es